

Báo cáo bảo mật Snyk (dễ hiểu)

Dự án: web-ctmtqg
Thời điểm quét (UTC): 2026-04-06T02:44:57.420Z
Hiển thị theo giờ Việt Nam: 09:44:57 6/4/2026

1. Tóm tắt cho lãnh đạo / phi kỹ thuật

- Thư viện (npm):** 42 phát hiện trên 4 nhóm manifest được quét.
- Phân bố mức độ (thư viện):** Nghiêm trọng 1, Cao 32, Trung bình 8, Thấp 1.
- Mã nguồn tự viết:** 14 phát hiện.
- Phân bố mức độ (mã nguồn):** Nghiêm trọng 0, Cao 0, Trung bình 14, Thấp 0.
- Hạ tầng dạng mã (IaC):** Không quét IaC trong lần này.
 - Quét toàn repo dễ vướng file trong node_modules. Thư mục CI/GitLab và docker-compose hiện không được Snyk xử lý như Terraform/Kubernetes/CloudFormation. Khi có thư mục Terraform/K8s riêng, hãy chạy quét riêng trên đó.

2. Các khái niệm được giải thích ngắn gọn

- Software Composition Analysis:** Software Composition Analysis — phân tích thư viện/phụ thuộc mở.
- Static Application Security Testing:** Static Application Security Testing — quét tĩnh mã nguồn.
- CVE:** Mã định danh lỗ hổng công khai.
- Điểm CVSS:** Điểm mức độ nghiêm trọng (thang điểm, càng cao càng nghiêm trọng).

3. Rủi ro từ thư viện (npm) — hiểu nhanh + việc cần làm

STT	Gói	Phiên bản	Mức độ	Hiểu đơn giản	CVE	Gợi ý khắc phục	Manifest
1	ajv	6.12.6	Cao	Tấn công làm regex xử lý quá lâu → có thể làm chậm hoặc treo dịch vụ (từ chối dịch vụ).	CVE-2025-69873	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 6.14.0, 8.18.0.	package-lock.json
2	ajv	6.12.6	Cao	Tấn công làm regex xử lý quá lâu → có thể làm chậm hoặc treo dịch vụ (từ chối dịch vụ).	CVE-2025-69873	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 6.14.0, 8.18.0.	package-lock.json
3	brace-expansion	1.1.12	Cao	Vòng lặp vô hạn có thể khiến tiến trình bị treo khi xử lý dữ liệu đặc biệt.	CVE-2026-33750	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 1.1.13, 2.0.3, 3.0.2, 5.0.5.	package-lock.json

4	brace-expansion	1.1.12	Cao	Vòng lặp vô hạn có thể khiến tiến trình bị treo khi xử lý dữ liệu đặc biệt.	CVE-2026-33750	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 1.1.13, 2.0.3, 3.0.2, 5.0.5.	package-lock.json
5	brace-expansion	1.1.12	Cao	Vòng lặp vô hạn có thể khiến tiến trình bị treo khi xử lý dữ liệu đặc biệt.	CVE-2026-33750	Xem khuyến nghị Snyk; phiên bản đã sửa: 1.1.13, 2.0.3, 3.0.2, 5.0.5.	package-lock.json
6	brace-expansion	2.0.2	Cao	Vòng lặp vô hạn có thể khiến tiến trình bị treo khi xử lý dữ liệu đặc biệt.	CVE-2026-33750	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 1.1.13, 2.0.3, 3.0.2, 5.0.5.	package-lock.json
7	brace-expansion	2.0.2	Cao	Vòng lặp vô hạn có thể khiến tiến trình bị treo khi xử lý dữ liệu đặc biệt.	CVE-2026-33750	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 1.1.13, 2.0.3, 3.0.2, 5.0.5.	package-lock.json
8	flatted	3.3.3	Cao	Độ quy quá sâu có thể gây tràn stack / treo ứng dụng.	CVE-2026-32141	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 3.4.0.	package-lock.json
9	flatted	3.3.3	Nghiêm trọng	Kê tấn công có thể "bơm" thuộc tính vào prototype object → thay đổi hành vi toàn app.	CVE-2026-33228	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 3.4.2.	package-lock.json
10	inflight	1.0.6	Trung bình	Tài nguyên (bộ nhớ, handle...) có thể không được giải phóng đúng cách.	—	Xem khuyến nghị Snyk; phiên bản đã sửa: —.	package-lock.json
11	minimatch	3.1.2	Cao	Tấn công làm regex xử lý quá lâu → có thể làm chậm hoặc treo dịch vụ (từ chối dịch vụ).	CVE-2026-26996	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 3.1.3, 4.2.4, 5.1.7, 6.2.1, 7.4.7, 8.0.5, 9.0.6, 10.2.1.	package-lock.json
12	minimatch	3.1.2	Cao	Thuật toán xử lý có độ phức tạp kém trong trường hợp	CVE-2026-27903	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã	package-lock.json

				xấu → dễ bị làm chậm có chủ đích.		sửa gợi ý: 3.1.3, 4.2.5, 5.1.8, 6.2.2, 7.4.8, 8.0.6, 9.0.7, 10.2.3.	
13	minimatch	3.1.2	Cao	Tấn công làm regex xử lý quá lâu → có thể làm chậm hoặc treo dịch vụ (từ chối dịch vụ).	CVE-2026-26996	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 3.1.3, 4.2.4, 5.1.7, 6.2.1, 7.4.7, 8.0.5, 9.0.6, 10.2.1.	package-lock.json
14	minimatch	3.1.2	Cao	Thuật toán xử lý có độ phức tạp kém trong trường hợp xấu → dễ bị làm chậm có chủ đích.	CVE-2026-27903	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 3.1.3, 4.2.5, 5.1.8, 6.2.2, 7.4.8, 8.0.6, 9.0.7, 10.2.3.	package-lock.json
15	minimatch	3.1.2	Cao	Tấn công làm regex xử lý quá lâu → có thể làm chậm hoặc treo dịch vụ (từ chối dịch vụ).	CVE-2026-26996	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 3.1.3, 4.2.4, 5.1.7, 6.2.1, 7.4.7, 8.0.5, 9.0.6, 10.2.1.	package-lock.json
16	minimatch	3.1.2	Cao	Thuật toán xử lý có độ phức tạp kém trong trường hợp xấu → dễ bị làm chậm có chủ đích.	CVE-2026-27903	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 3.1.3, 4.2.5, 5.1.8, 6.2.2, 7.4.8, 8.0.6, 9.0.7, 10.2.3.	package-lock.json
17	minimatch	3.1.2	Cao	Tấn công làm regex xử lý quá lâu → có thể làm chậm hoặc treo dịch vụ (từ chối dịch vụ).	CVE-2026-26996	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 3.1.3, 4.2.4, 5.1.7, 6.2.1, 7.4.7, 8.0.5, 9.0.6, 10.2.1.	package-lock.json
18	minimatch	3.1.2	Cao	Thuật toán xử lý có độ phức tạp kém trong trường hợp xấu → dễ bị làm chậm có chủ đích.	CVE-2026-27903	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 3.1.3, 4.2.5, 5.1.8, 6.2.2, 7.4.8, 8.0.6, 9.0.7, 10.2.3.	package-lock.json
19	minimatch	3.1.2	Cao	Tấn công làm regex xử lý	CVE-2026-26996	Ưu tiên nâng cấp (có đường	package-lock.json

				quá lâu → có thể làm chậm hoặc treo dịch vụ (từ chối dịch vụ).		nâng cấp). Phiên bản đã sửa gợi ý: 3.1.3, 4.2.4, 5.1.7, 6.2.1, 7.4.7, 8.0.5, 9.0.6, 10.2.1.	
20	minimatch	3.1.2	Cao	Thuật toán xử lý có độ phức tạp kém trong trường hợp xấu → dễ bị làm chậm có chủ đích.	CVE-2026-27903	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 3.1.3, 4.2.5, 5.1.8, 6.2.2, 7.4.8, 8.0.6, 9.0.7, 10.2.3.	package-lock.json
21	minimatch	3.1.2	Cao	Tấn công làm regex xử lý quá lâu → có thể làm chậm hoặc treo dịch vụ (từ chối dịch vụ).	CVE-2026-26996	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 3.1.3, 4.2.4, 5.1.7, 6.2.1, 7.4.7, 8.0.5, 9.0.6, 10.2.1.	package-lock.json
22	minimatch	3.1.2	Cao	Thuật toán xử lý có độ phức tạp kém trong trường hợp xấu → dễ bị làm chậm có chủ đích.	CVE-2026-27903	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 3.1.3, 4.2.5, 5.1.8, 6.2.2, 7.4.8, 8.0.6, 9.0.7, 10.2.3.	package-lock.json
23	minimatch	3.1.2	Cao	Tấn công làm regex xử lý quá lâu → có thể làm chậm hoặc treo dịch vụ (từ chối dịch vụ).	CVE-2026-26996	Xem khuyến nghị Snyk; phiên bản đã sửa: 3.1.3, 4.2.4, 5.1.7, 6.2.1, 7.4.7, 8.0.5, 9.0.6, 10.2.1.	package-lock.json
24	minimatch	3.1.2	Cao	Thuật toán xử lý có độ phức tạp kém trong trường hợp xấu → dễ bị làm chậm có chủ đích.	CVE-2026-27903	Xem khuyến nghị Snyk; phiên bản đã sửa: 3.1.3, 4.2.5, 5.1.8, 6.2.2, 7.4.8, 8.0.6, 9.0.7, 10.2.3.	package-lock.json
25	minimatch	9.0.5	Cao	Tấn công làm regex xử lý quá lâu → có thể làm chậm hoặc treo dịch vụ (từ chối dịch vụ).	CVE-2026-26996	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 3.1.3, 4.2.4, 5.1.7, 6.2.1, 7.4.7, 8.0.5, 9.0.6, 10.2.1.	package-lock.json
26	minimatch	9.0.5	Cao	Tấn công làm regex xử lý	CVE-2026-27904	Ưu tiên nâng cấp (có đường	package-lock.json

				quá lâu → có thể làm chậm hoặc treo dịch vụ (từ chối dịch vụ).		nâng cấp). Phiên bản đã sửa gợi ý: 8.0.6, 9.0.7, 10.2.3.	
27	minimatch	9.0.5	Cao	Thuật toán xử lý có độ phức tạp kém trong trường hợp xấu → dễ bị làm chậm có chủ đích.	CVE-2026-27903	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 3.1.3, 4.2.5, 5.1.8, 6.2.2, 7.4.8, 8.0.6, 9.0.7, 10.2.3.	package-lock.json
28	minimatch	5.1.6	Cao	Tấn công làm regex xử lý quá lâu → có thể làm chậm hoặc treo dịch vụ (từ chối dịch vụ).	CVE-2026-26996	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 3.1.3, 4.2.4, 5.1.7, 6.2.1, 7.4.7, 8.0.5, 9.0.6, 10.2.1.	package-lock.json
29	minimatch	5.1.6	Cao	Thuật toán xử lý có độ phức tạp kém trong trường hợp xấu → dễ bị làm chậm có chủ đích.	CVE-2026-27903	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 3.1.3, 4.2.5, 5.1.8, 6.2.2, 7.4.8, 8.0.6, 9.0.7, 10.2.3.	package-lock.json
30	next	16.0.10	Cao	Không giới hạn tài nguyên → có thể bị lạm dụng để làm cạn kiệt CPU/bộ nhớ.	CVE-2025-59471	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 15.5.10, 16.1.1-canary.15, 16.1.5.	package-lock.json
31	next	16.0.10	Cao	Không giới hạn tài nguyên → có thể bị lạm dụng để làm cạn kiệt CPU/bộ nhớ.	CVE-2025-59472	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 15.6.0-canary.61, 16.1.1-canary.16, 16.1.5.	package-lock.json
32	next	16.0.10	Trung bình	Không giới hạn tài nguyên → có thể bị lạm dụng để làm cạn kiệt CPU/bộ nhớ.	CVE-2026-27980	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 16.1.7, 16.2.0-canary.54.	package-lock.json
33	next	16.0.10	Trung bình	Trang độc hại có thể lừa trình duyệt gửi yêu cầu thay	CVE-2026-27978	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã	package-lock.json

				mặt người dùng đã đăng nhập.		sửa gợi ý: 16.1.7, 16.2.0-canary.102.	
34	next	16.0.10	Trung bình	Xung đột cách hiểu HTTP giữa proxy và server → có thể bị lách kiểm soát hoặc cache poisoning.	CVE-2026-29057	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 15.5.13, 16.1.7, 16.2.0-canary.102.	package-lock.json
35	next	16.0.10	Thấp	WebSocket có thể chấp nhận kết nối từ nguồn không đáng tin nếu không kiểm tra Origin.	CVE-2026-27977	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 16.1.7, 16.2.0-canary.102.	package-lock.json
36	picomatch	2.3.1	Cao	Tấn công làm regex xử lý quá lâu → có thể làm chậm hoặc treo dịch vụ (từ chối dịch vụ).	CVE-2026-33671	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 2.3.2, 3.0.2, 4.0.4.	package-lock.json
37	picomatch	2.3.1	Trung bình	Kê tấn công có thể "bơm" thuộc tính vào prototype object → thay đổi hành vi toàn app.	CVE-2026-33672	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 2.3.2, 3.0.2, 4.0.4.	package-lock.json
38	picomatch	4.0.3	Cao	Tấn công làm regex xử lý quá lâu → có thể làm chậm hoặc treo dịch vụ (từ chối dịch vụ).	CVE-2026-33671	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 2.3.2, 3.0.2, 4.0.4.	package-lock.json
39	picomatch	4.0.3	Trung bình	Kê tấn công có thể "bơm" thuộc tính vào prototype object → thay đổi hành vi toàn app.	CVE-2026-33672	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 2.3.2, 3.0.2, 4.0.4.	package-lock.json
40	xlsx	0.18.5	Trung bình	Kê tấn công có thể "bơm" thuộc tính vào prototype object → thay đổi hành vi toàn app.	CVE-2023-30533	Xem khuyến nghị Snyk; phiên bản đã sửa: —.	package-lock.json
41	xlsx	0.18.5	Cao	Tấn công làm regex xử lý quá lâu → có thể làm chậm hoặc treo dịch vụ (từ chối dịch vụ).	CVE-2024-22363	Xem khuyến nghị Snyk; phiên bản đã sửa: —.	package-lock.json

42	pnpm	9.15.9	Trung bình	Thuật toán băm yếu → dễ bị tấn công dò/hợp lệ hóa (tùy ngữ cảnh sử dụng).	CVE-2024-47829	Ưu tiên nâng cấp (có đường nâng cấp). Phiên bản đã sửa gợi ý: 10.0.0-alpha.0.	.npm-ci/_npx/8959f4e966f464e2/package-lock.json
----	------	--------	------------	---	----------------	---	---

Ghi chú: Một lỗ hổng có thể xuất hiện nhiều dòng nếu có nhiều đường phụ thuộc khác nhau tới cùng gói lỗi thời.

4. Rủi ro trong mã nguồn (SAST)

STT	Vấn đề	Mức độ	Hiểu đơn giản	File	Dòng
1	Use of Externally-Controlled Format String	Trung bình	Dữ liệu do người dùng kiểm soát đi vào chuỗi định dạng (format) → có thể rò rỉ thông tin hoặc hành vi không an toàn.	src/app/services/account-manager/route.ts	122
2	Use of Externally-Controlled Format String	Trung bình	Dữ liệu do người dùng kiểm soát đi vào chuỗi định dạng (format) → có thể rò rỉ thông tin hoặc hành vi không an toàn.	supabase/functions/chart_data/index.ts	136
3	Use of Externally-Controlled Format String	Trung bình	Dữ liệu do người dùng kiểm soát đi vào chuỗi định dạng (format) → có thể rò rỉ thông tin hoặc hành vi không an toàn.	supabase/functions/chart_data/index.ts	258
4	Use of Externally-Controlled Format String	Trung bình	Dữ liệu do người dùng kiểm soát đi vào chuỗi định dạng (format) → có thể rò rỉ thông tin hoặc hành vi không an toàn.	supabase/functions/chart_data/index.ts	289
5	Use of Externally-Controlled Format String	Trung bình	Dữ liệu do người dùng kiểm soát đi vào chuỗi định dạng (format) → có thể rò rỉ thông tin hoặc hành vi không an toàn.	supabase/functions/table_data/index.ts	323
6	Use of Externally-Controlled Format String	Trung bình	Dữ liệu do người dùng kiểm soát đi vào chuỗi định dạng (format) → có thể rò rỉ thông tin hoặc hành vi không an toàn.	supabase/functions/table_data/index.ts	368
7	Use of Externally-Controlled Format String	Trung bình	Dữ liệu do người dùng kiểm soát đi vào chuỗi định dạng (format) → có thể rò	supabase/functions/table_data/index.ts	1004

			rỉ thông tin hoặc hành vi không an toàn.		
8	Use of Externally-Controlled Format String	Trung bình	Dữ liệu do người dùng kiểm soát đi vào chuỗi định dạng (format) → có thể rò rỉ thông tin hoặc hành vi không an toàn.	supabase/function s/table_data/index .ts	1065
9	Use of Externally-Controlled Format String	Trung bình	Dữ liệu do người dùng kiểm soát đi vào chuỗi định dạng (format) → có thể rò rỉ thông tin hoặc hành vi không an toàn.	supabase/function s/table_data/index .ts	1126
10	Use of Externally-Controlled Format String	Trung bình	Dữ liệu do người dùng kiểm soát đi vào chuỗi định dạng (format) → có thể rò rỉ thông tin hoặc hành vi không an toàn.	supabase/function s/table_data/index .ts	1187
11	Use of Externally-Controlled Format String	Trung bình	Dữ liệu do người dùng kiểm soát đi vào chuỗi định dạng (format) → có thể rò rỉ thông tin hoặc hành vi không an toàn.	supabase/function s/table_data/index .ts	1251
12	Use of Externally-Controlled Format String	Trung bình	Dữ liệu do người dùng kiểm soát đi vào chuỗi định dạng (format) → có thể rò rỉ thông tin hoặc hành vi không an toàn.	supabase/function s/table_data/index .ts	1265
13	Use of Externally-Controlled Format String	Trung bình	Dữ liệu do người dùng kiểm soát đi vào chuỗi định dạng (format) → có thể rò rỉ thông tin hoặc hành vi không an toàn.	src/app/services/ account- manager/route.ts	243
14	Use of Hardcoded Passwords	Trung bình	Mật khẩu hoặc chuỗi nhạy cảm bị ghi cứng trong code → lộ khi public repo hoặc build.	src/components/ac count- manager/import- account- dialog.tsx	73

5. Bước tiếp theo đề xuất

1. Nâng cấp **next** và các gói trực tiếp theo bảng Snyk (ưu tiên mức Cao / Nghiêm trọng).
2. Chạy `pnpm update` / chỉnh `package.json` rồi kiểm tra lại bằng `snyk test`.
3. Với SAST: rà soát format string và bỏ hardcoded mật khẩu khỏi code (dùng biến môi trường / vault).
4. Khi có thư mục Terraform/Kubernetes, chạy `snyk iac test <thư_mục>` riêng.

Báo cáo được tạo tự động từ `reports/snyk-full-report.json` — không thay thế đánh giá thủ công hoặc pentest.